

OpenShift Compliance Operator

OpenShift Anwendertreffen Community
Session

(Red Hat) Community Events

- 18./19.Juni: [DevConf.CZ](#) (Brno)
- 23.Juni: Securing your Software Pipeline w/ Red Hat Advanced Developer Suite
- 25./26.Juni: OWAS Global AppSec EU 2026, Wien
- 28.September: 35. OpenShift Anwendertreffen @ TU Wien
- 13./14.Oktober: Austria @ Innovate Together, Sibenik / Kroatien

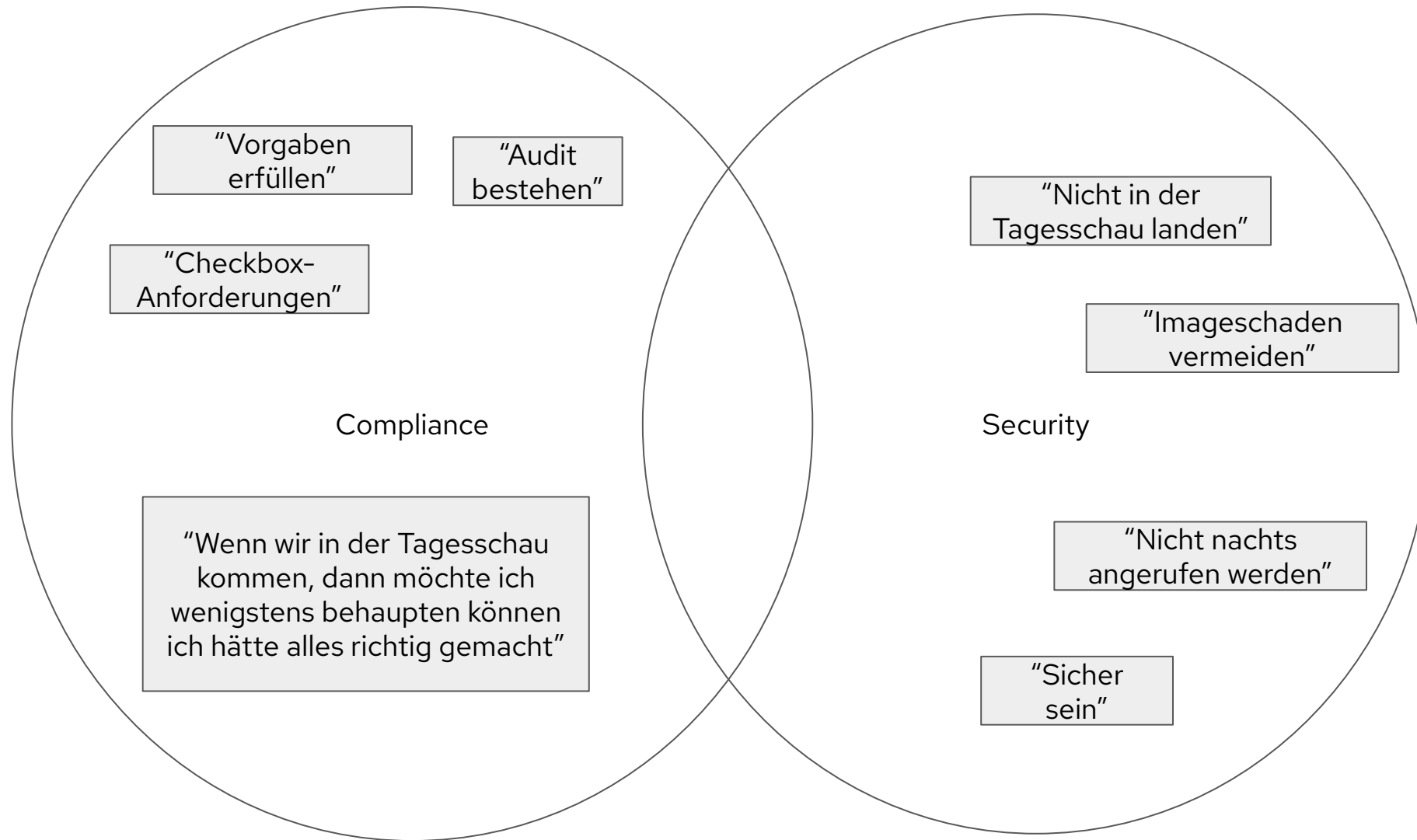


<https://www.redhat.com/austria-events>



Steffen Lützenkirchen
Lead Architect Public Sector Germany

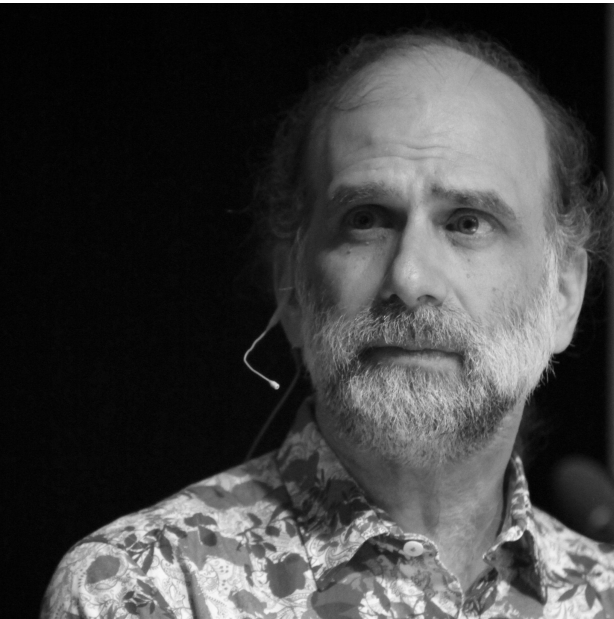
- based in Germany, near Cologne
- In IT since 2008
- Working with Linux since 2014
- Working with Containers since 2017
- Working at Red Hat since Nov 2022
 - Focus on Compliance & Security



Incompliant but somewhat secure



Compliant but insecure



“Security is a process, not a product.”

Bruce Schneier

Cryptographer, security blogger, and author

Source:

Image released under CC BY-SA 2.0 FR, and available from https://commons.wikimedia.org/wiki/File:Bruce_Schneier_at_CoPS2013-IMG_9174.jpg. License available from <https://creativecommons.org/licenses/by-sa/2.0/fr/legalcode>

We change configurations in our systems often. But we do not know, if this impacts our compliance state.

My GRC-Team requires me to report my compliance status to them

Auditing on a yearly base leaves me with a long uncovered timeframe. I want to do compliance continuously

I have to comply with the regulation and don't know where to start or what to configure

I want/need to improve my security/compliance posture

Der Werkzeugkasten von Red Hat



Secure-By-Default

OCP erfüllt schon im Auslieferungszustand viele Anforderungen. Einige müssen lediglich Organisationsspezifisch konfiguriert werden



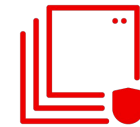
Security-Operator

Insbesondere für den erhöhten Schutzbedarf (BSI) gibt es zusätzliche Operator (File Integrity, Security Profiles, Compliance), die weitere Sicherheitsfunktionen nachrüsten



Admission Control

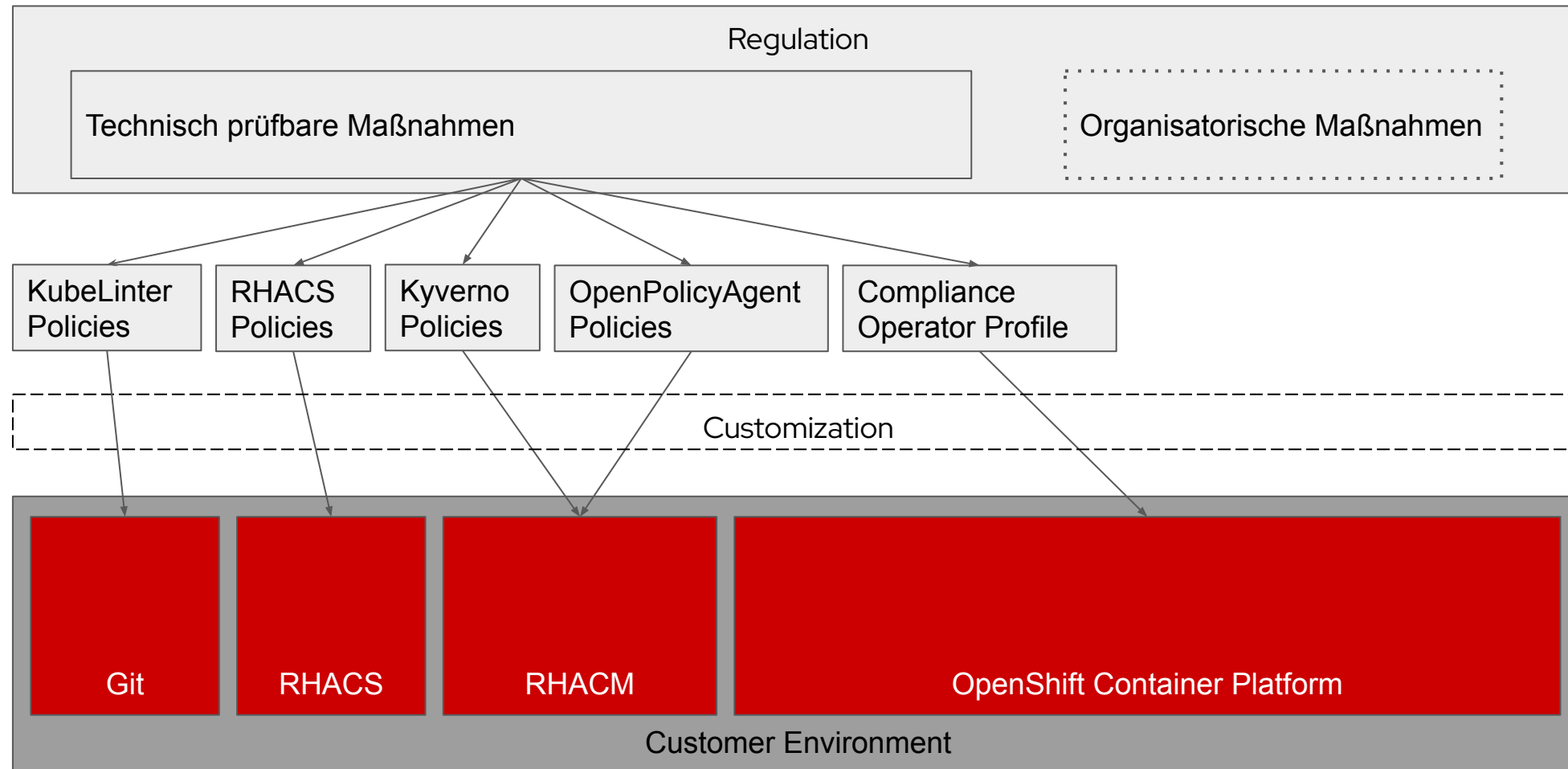
Red Hat stellt verschiedene Admission Controller bereit, die dabei helfen, dass nur sichere und den Vorgaben entsprechende Workloads auf OpenShift kommen.



Technische Prüfungen

Für technisch prüfbare Anforderungen werden durch Red Hat Mitarbeiter öffentlich Regelwerke zur Verfügung gestellt, die bei der Adaption unterstützen. Es gibt supportete Regelwerke in den Produkten.

Technische Prüfungen



KubeLinter

Ensuring checks early in the development process



Linters

KubeLinter analyzes Kubernetes YAML files and Helm charts, and checks them against a variety of best practices, with a focus on production readiness and security.



Pre-Commit Hook

By adding KubeLinter to your Developers Pre-Commit Hook you can reach a very short Feedback Cycle



BSI Ruleset

We developed an (upstream) Ruleset for KubeLinter on opencode.de

OpenPolicyAgent

Providing an extensive language for checks



Conftest / Gator

Validation of local yaml files early in the development cycle



Gatekeeper

Validation and Mutation as Admission Controller in a running Kubernetes Environment.



BSI Ruleset

There currently is no existing known ruleset for BSI Grundschutz

Kyverno

Write rules in pure yaml



Kyverno CLI

Use Kyverno in your CI/CD Pipeline to check



Kyverno Admission Control

validate, mutate, generate, and cleanup Kubernetes Resources



BSI Ruleset

There is an (incomplete) Ruleset for Kyverno on opencode.de

Red Hat Advanced Cluster Security

Security across Build, Deploy and Run



roxctl

Use roxctl to check your deployments against your rules in CI/CD



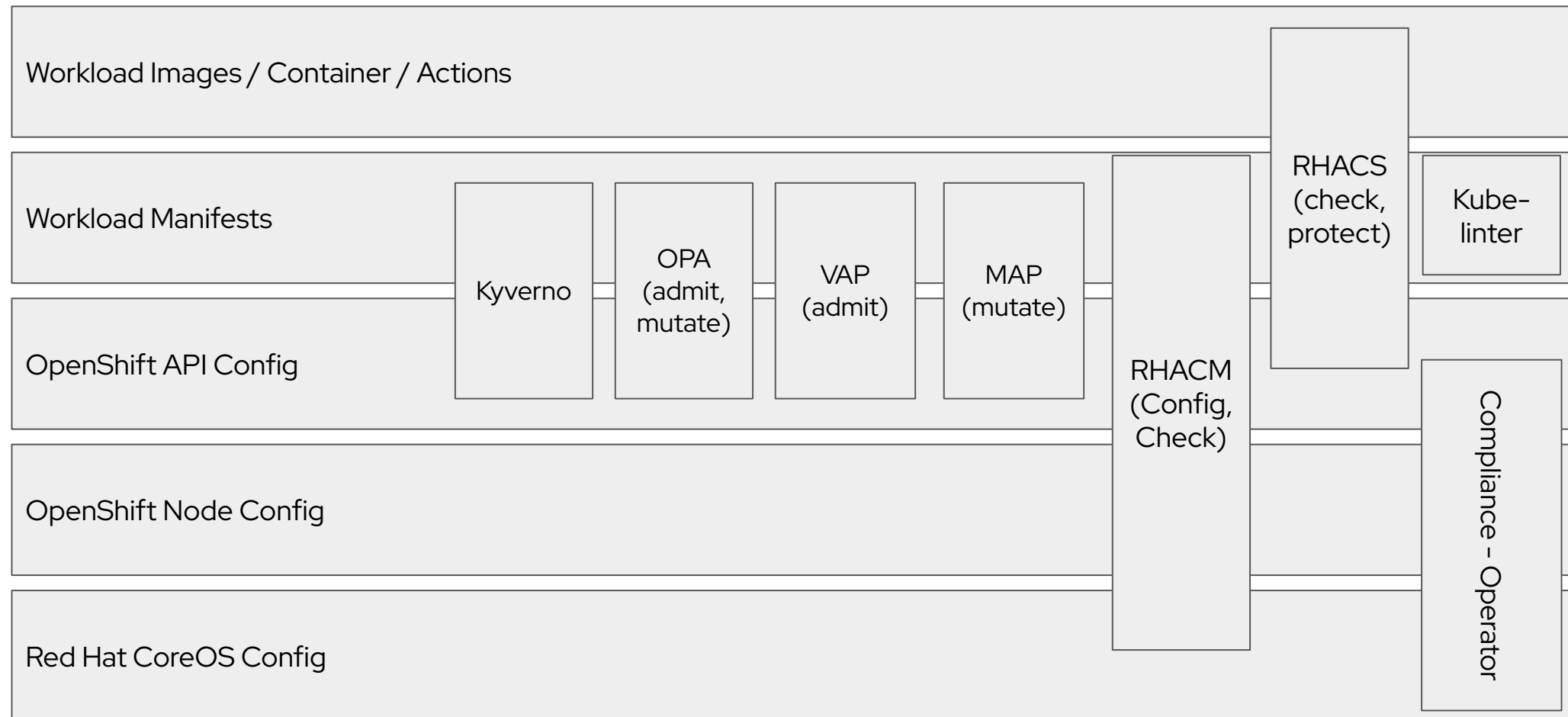
Admission Control &
Runtime Protection

Not only check the deployments when on CREATE/UPDATE but also check running processes against baseline and packages for CVEs



BSI Ruleset

We developed an (upstream) Ruleset for RHACS on opencode.de



Compliance Operator

Automating compliance checks for OpenShift and CoreOS



compliance-operator

The operator lets the administrator describe the desired compliance state of a cluster and provides them with an overview of gaps and ways to remediate them.



OpenSCAP

NIST-certified tool to scan and enforce security policies provided by the content.

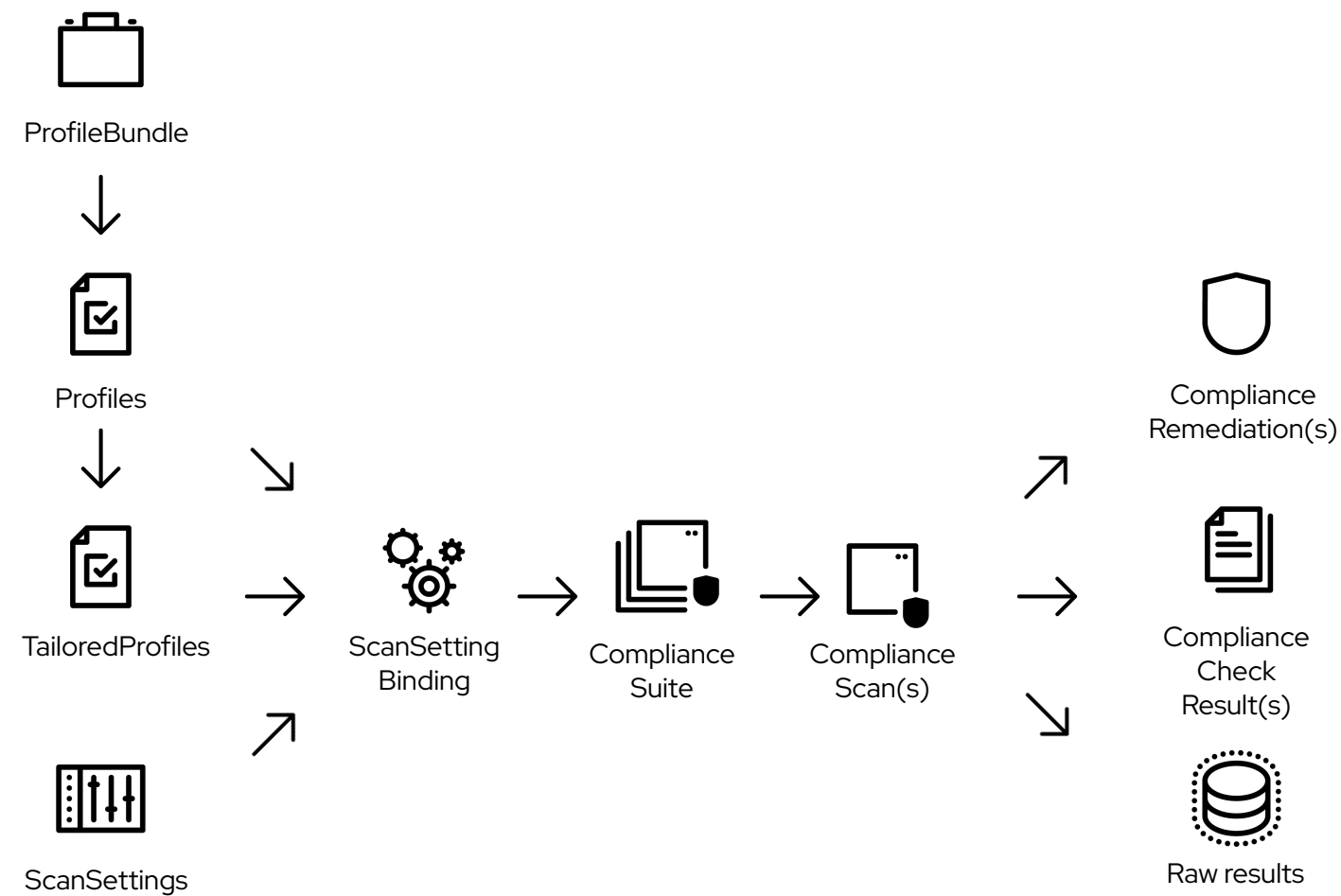


Content

The compliance checks themselves are delivered through SCAP content, with a lifecycle independent from the operator or the OpenSCAP scanner.

This is done as part of the
ComplianceAsCode project





NAME	AGE	VERSION
ocp4-bsi	93d	2022
ocp4-bsi-2022	93d	2022
ocp4-bsi-node	93d	2022
ocp4-bsi-node-2022	93d	2022
ocp4-cis	93d	1.9.0
ocp4-cis-1-7	93d	1.7.0
ocp4-cis-1-9	54d	1.9.0
ocp4-cis-node	93d	1.9.0
ocp4-cis-node-1-7	93d	1.7.0
ocp4-cis-node-1-9	54d	1.9.0
ocp4-e8	93d	
ocp4-high	93d	Revision 4
ocp4-high-node	93d	Revision 4
ocp4-high-node-rev-4	93d	Revision 4
ocp4-high-rev-4	93d	Revision 4
ocp4-moderate	93d	Revision 4
ocp4-moderate-node	93d	Revision 4
ocp4-moderate-node-rev-4	93d	Revision 4
ocp4-moderate-rev-4	93d	Revision 4
ocp4-nerc-cip	93d	
ocp4-nerc-cip-node	93d	
ocp4-pci-dss	93d	3.2.1
ocp4-pci-dss-3-2	93d	3.2.1
ocp4-pci-dss-4-0	93d	4.0.0
ocp4-pci-dss-node	93d	3.2.1
ocp4-pci-dss-node-3-2	93d	3.2.1
ocp4-pci-dss-node-4-0	93d	4.0.0
ocp4-stig	93d	V2R3
ocp4-stig-node	93d	V2R3
ocp4-stig-node-v2r2	93d	V2R2
ocp4-stig-node-v2r3	93d	V2R3
ocp4-stig-v2r2	93d	V2R2
ocp4-stig-v2r3	93d	V2R3
rhcos4-bsi	93d	2022
rhcos4-bsi-2022	93d	2022
rhcos4-e8	93d	
rhcos4-high	93d	Revision 4
rhcos4-high-rev-4	93d	Revision 4
rhcos4-moderate	93d	Revision 4
rhcos4-moderate-rev-4	93d	Revision 4
rhcos4-nerc-cip	93d	
rhcos4-stig	93d	V2R3
rhcos4-stig-v2r2	93d	V2R2
rhcos4-stig-v2r3	93d	V2R3

Compliance Operator Value

For different Roles



Have sufficient reporting to your managers and GRC*-Entities. Utilize your engineers not on reporting or creating compliance-scripts but on innovation for your products

Manager



Automate the boring reporting tasks and utilize your time for more interesting stuff. Debugging a rare issue or improving your platform.

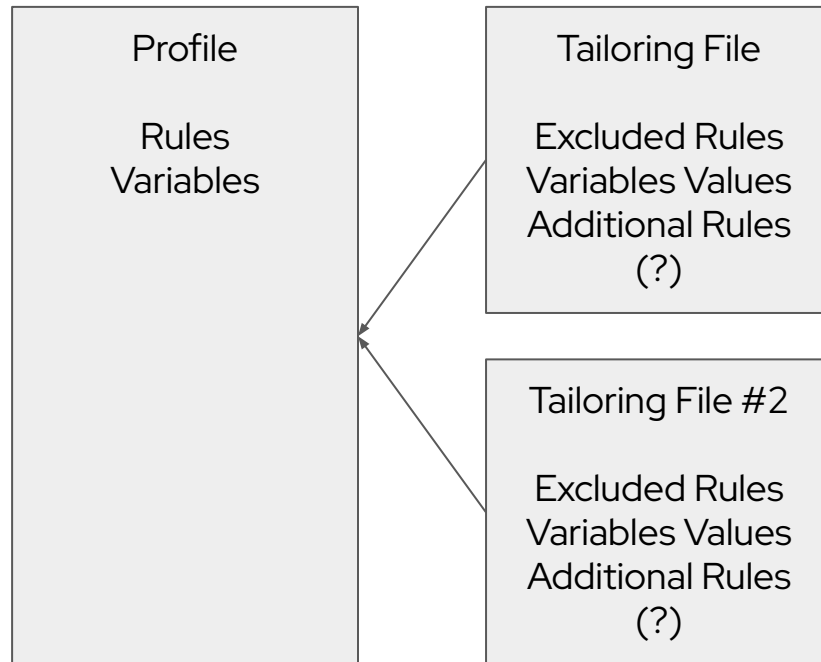
Engineer



Paper does not create security. CO provides you with EVIDENCE/PROOF that measures are implemented and regularly checked. You can audit more in shorter time.

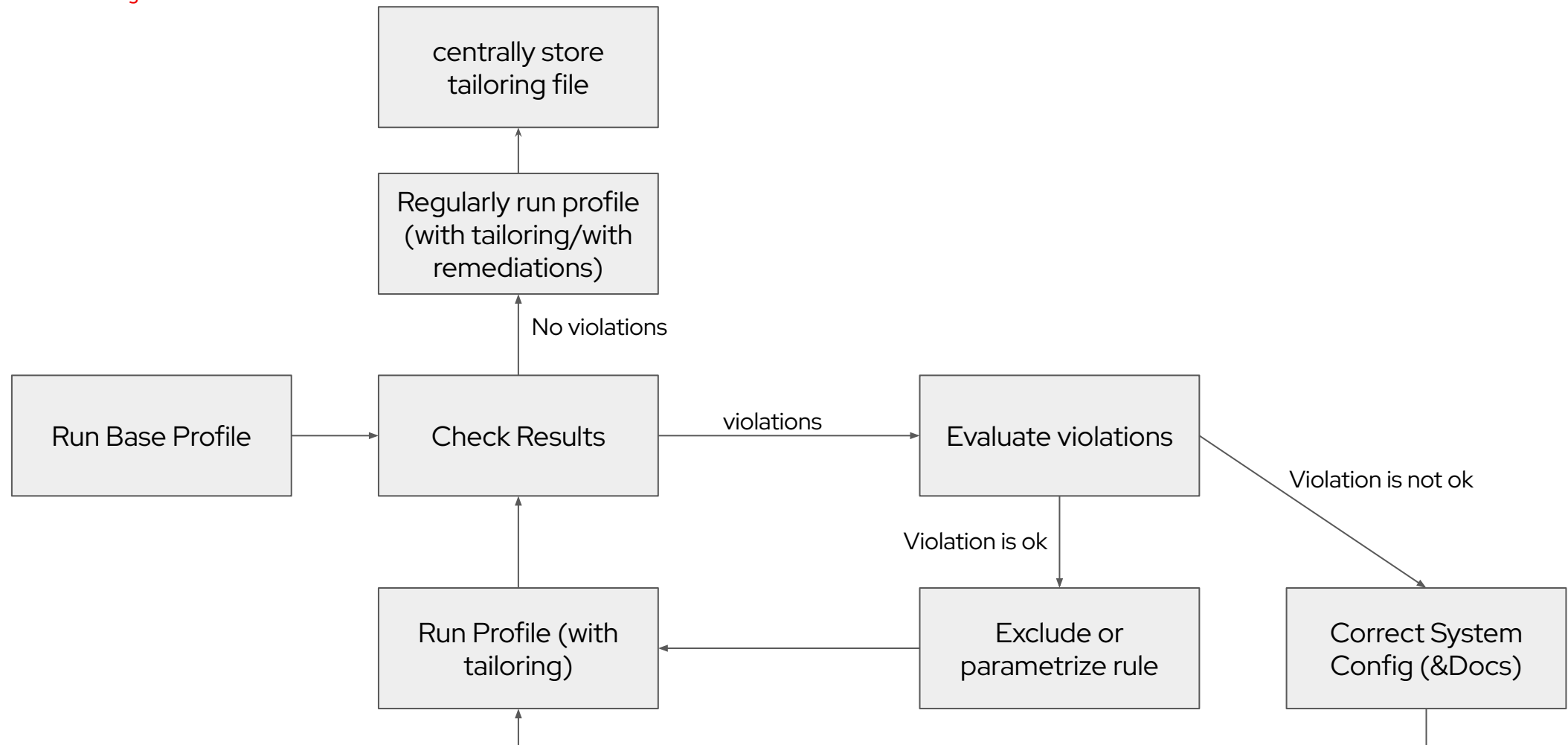
Auditor / GRC Team

Tailoring



A tailoring file includes instructions on what to do with the rules from a specific profile. It is a customization file, which does not change the content of the profile, but more likely changes the way how it is evaluated.

You can have multiple tailoring files for a profile. For example each and every service which is a little bit "special" can have its own tailoring.

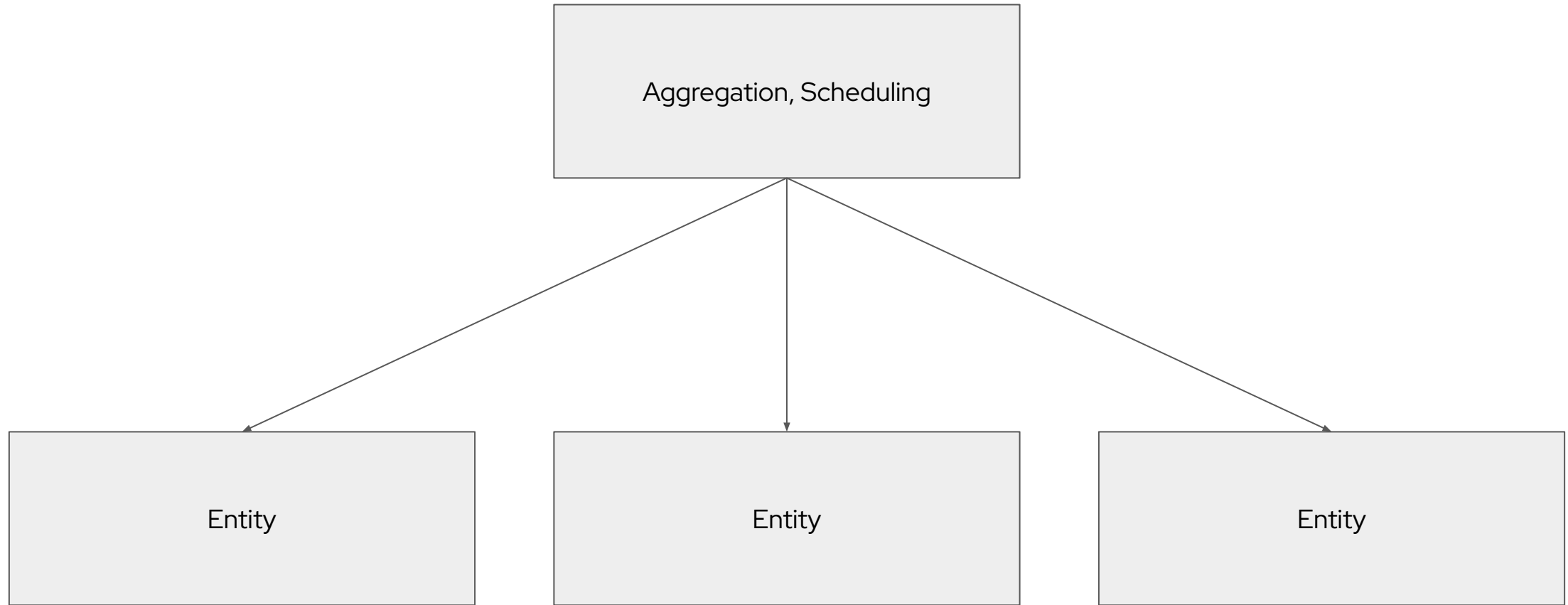


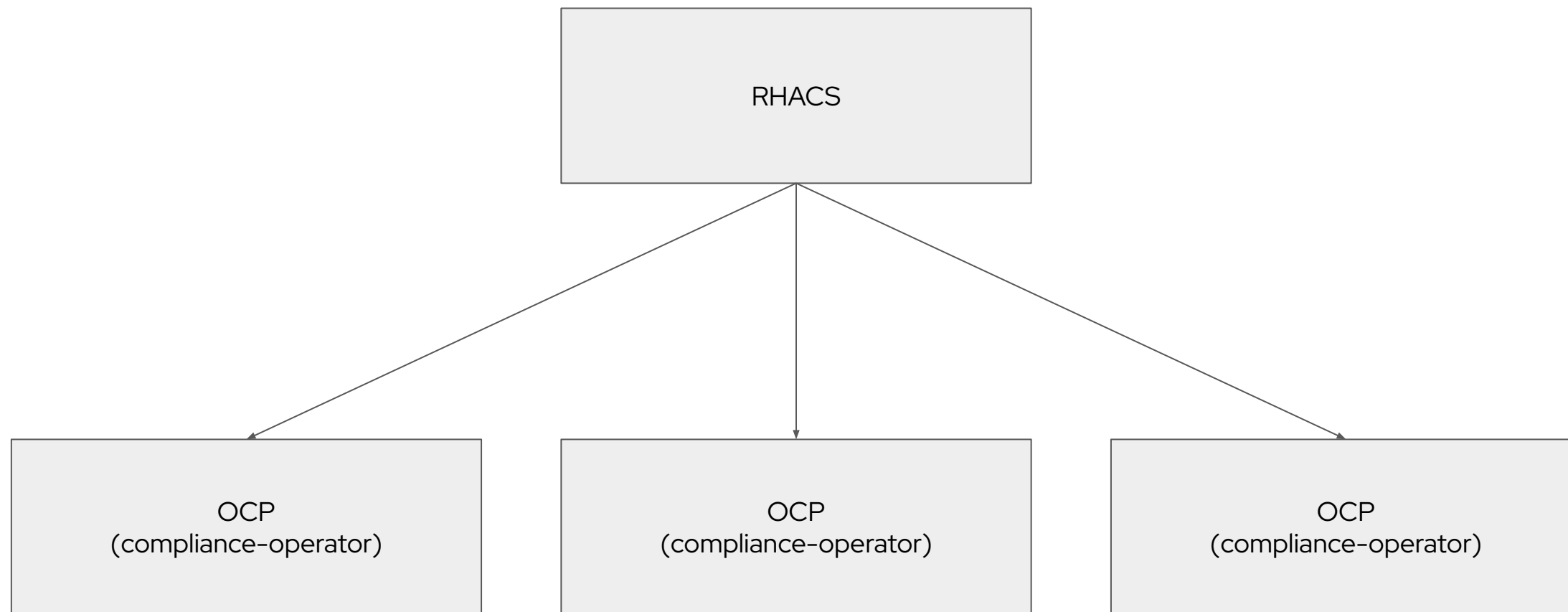
- Configuring the system in another way than the remediation/the rule expects
- Multiple profiles which have different requirements
- Too keep it manageable
 - Less profiles are better
 - Less tailoring is better

Exkurs

Requirement-Group	OpenShift	Compliance Operator
Access Control & Identity Management / Multi Factor Authentication	OAuth via Keycloak	CustomRule for LeastPrivilege, UserLists, profiles provide rules for authentication integration / IdP, Check OAuth config
Cryptography & Data Security	Etdcd encryption, encrypted volumes, encrypted disks	Rules for etcd-encryption, CustomRules for volumes/disks
Incident Detection & Continuous Monitoring	LogForwarding to SIEMs (or via Agents)	Rules for audit-configuration
Business Continuity & Backup Management	OADP, (automated [TP]) etcd-backup	Rules for OADP, CustomRules for (automated) etcd-backup
Supply Chain Vetting	Enforce via TrustedRegistries, SignedImages, ...	Rules for TrustedRegistry and SignedImages

Red Hat Advanced Cluster Security for Kubernetes (RHACS)



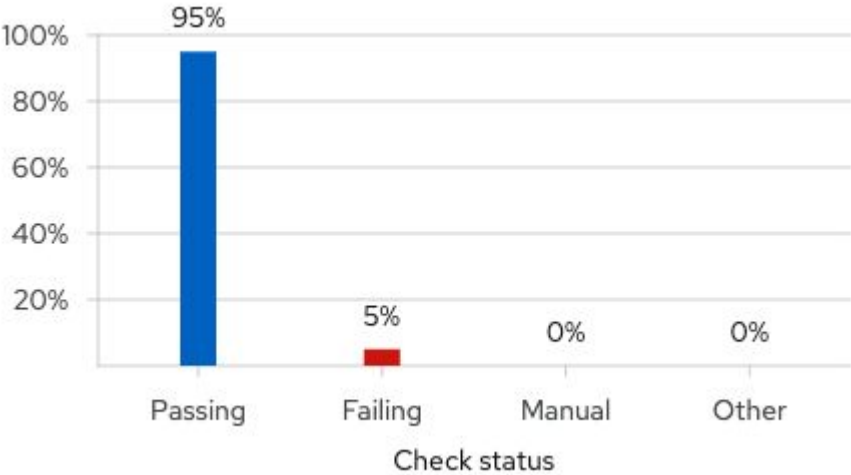


Schedules

Configure scan schedules to run profile compliance checks on selected clusters

Create scan schedule

1 - 4 of 4						<<	<	1	>	>>
Name	Schedule	Last scanned	Clusters	Profiles	My last job status					
bsi-ocp	Daily at 00:30 UTC	2026-06-10 07:05 UTC	2 clusters	ocp4-bsi-2022	None					
bsi-ocp-node	Daily at 01:00 UTC	2026-06-10 09:50 UTC	2 clusters	ocp4-bsi-node-2022	None					
cis-1	Daily at 01:30 UTC	2026-06-10 09:47 UTC	stormshift-ocp3	ocp4-cis	None					
rhcos-bsi	Daily at 01:00 UTC	2026-06-10 09:49 UTC	2 clusters	rhcos4-bsi-2022	None					



Create scan schedule

I-Public

- 1 Set parameters
- 2 Select clusters
- 3 Select profiles
- 4 Configure report
- 5 Review

Parameters

Set name and schedule to scan on a recurring basis

Name *

demo-scan

Name can contain only lowercase alphanumeric characters, hyphen '-' or period '.', and start and end with an alphanumeric character.

Description

Schedule

Frequency * **On day(s)**

Daily Select days

Time *

00:30

Select or enter scan time between 00:00 and 23:59 UTC

ocp4-bsi-configure-network-bandwidth	BSI SYS.1.6.A15	0 clusters	0 clusters	1 cluster	0 clusters	0%
ocp4-bsi-configure-network-policies	4 controls	1 cluster	0 clusters	0 clusters	0 clusters	100%
BSI APP.4.4.A18 BSI APP.4.4.A7 BSI SYS.1.6.A21 BSI SYS.1.6.A5						

DEMO